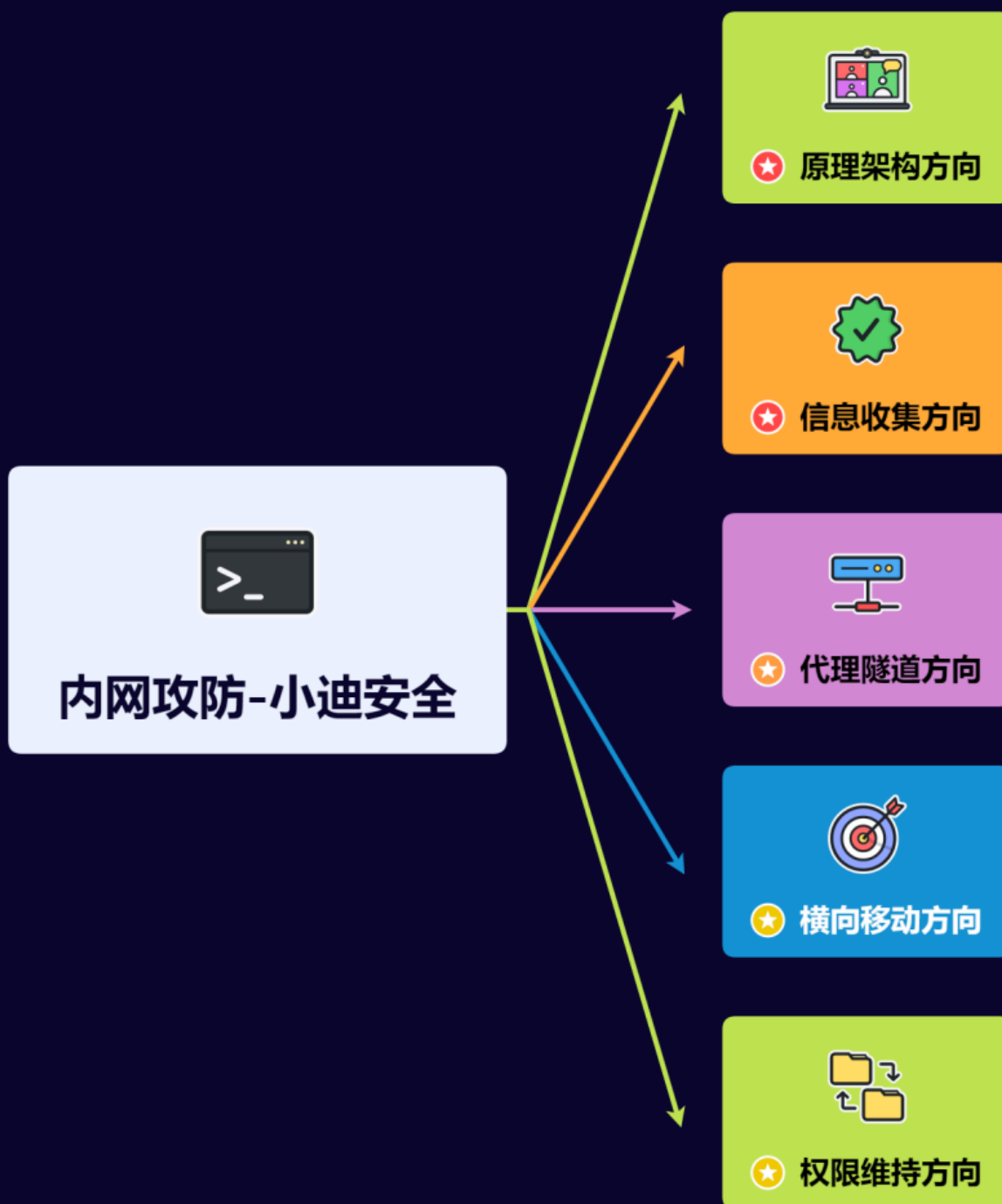


Day176 内网对抗-信息收集篇&SPN 扫描&DC 定位&角色区域定性&服务探针&安全防护&凭据获取



1.知识点

- 1、基石框架篇-单域架构-权限控制-用户和网络
- 2、基石框架篇-单域架构-环境搭建-准备和加入
- 3、基石框架篇-单域架构-信息收集-手工和工具

-
- 1、基石框架篇-父域子域架构-权限控制-用户和网络
 - 2、基石框架篇-父域子域架构-环境搭建-准备和加入
 - 3、基石框架篇-父域子域架构-信息收集-手工和工具

-
- 1、基石框架篇-域树&域林架构-权限控制-用户和网络
 - 2、基石框架篇-域树&域林架构-环境搭建-准备和加入
 - 3、基石框架篇-域树&域林架构-信息收集-手工和工具

-
- 1、代理隧道篇-代理通讯网络不可达-正反向连接上线
 - 2、代理隧道篇-代理通讯网络不可达-SockS代理配置

-
- 1、代理隧道篇-单向防火墙&双向防火墙-命令关闭
 - 2、代理隧道篇-单向防火墙&双向防火墙-正向反向
 - 3、代理隧道篇-单向防火墙&双向防火墙-隧道技术

-
- 1、隧道技术篇-网络层-ICMP协议-判断&封装&建立&穿透
 - 2、隧道技术篇-传输层-DNS协议-判断&封装&建立&穿透
 - 3、隧道技术篇-表示层-SMB协议-判断&封装&建立&穿透

-
- 1、C2/C2上线-CrossC2插件-多系统平台支持
 - 2、隧道技术篇-应用层-SSH协议-判断&封装&建立&穿透
 - 3、隧道技术篇-应用层-HTTP协议-判断&封装&建立&穿透

-
- 1、隧道技术篇-传输层-工具项目-Frp&Nps&Chisel
 - 2、隧道技术篇-传输层-端口转发&Socks建立&C2上线

-
- 1、信息收集篇-网络架构-出网&角色&服务&成员
 - 2、信息收集篇-安全防护-杀毒&防火墙&流量监控
 - 3、信息收集篇-密码凭据-系统&工具&网站&网络

2.详细点



- 1 1、认知处于什么网络环境下
- 2 2、认知内网域分类及成员架构
- 3 3、认知信息收集有那些重要信息
- 4 4、认知代理隧道有那些方法技术
- 5 5、认知横向移动有那些方法技术
- 6 5、认知权限维持有那些方法技术

2.1 工作组



- 1 将不同的计算机按照功能分别列入不同的工作组。想要访问某个部门的资源，只要在“网络”里面双击该部门的工作组名。工作组就像一个可以自由进入和退出的社团，方便同组的计算机相互访问，工作组没有集中管理作用，工作组里的计算机都是相互对等的（即没有服务器和客户机之分）。对局域网中的计算机进行分类，使得网络更有序。计算机的管理依然是各自为政，所有计算机依然是对等的，松散会员制，可以随意加入和退出，且不同工作组之间的共享资源可以相互访问。

2.2 内网域



- 1 分类：单域、子域、父域、域树、域森林、DNS域名服务器
- 2 “域”是一个有安全边界的计算机组合（一个域中的用户无法访问另一个域中的资源），域内资源由一台域控制器（Domain Controller, DC）集中管理，用户名和密码是放在域控制器去验证的。
- 3 优点：通过组策略来统一管理。
- 4 单域：即只有一个域的网络环境，一般需要两台DC，一台DC，另一台备用DC（容灾）
- 5 父子域：类比公司总部和公司分部的关系，总部的域称为父域，各分部的域称为该域的子域。使用父子域的好处：
- 6
 - 减小了域之间信息交互的压力（域内信息交互不会压缩，域间信息交互可压缩）
 - 不同的子域可以指定特定的安全策略
- 8 父子域中域名使用一个.表示一个层次，类似于DNS域名表示方式，子域只能使用父域的名字作为域名后缀
- 9 域树：多个域通过建立信任关系组成的集合。若两个域之间需要相互访问，需要建立信任关系（Trust Relation），通过信任关系可以将父子域连接成树状结构
- 10 域森林：多个域树通过建立信任关系组成的集合。
- 11 域名服务器：实现域名到IP地址的转换。由于域中计算机使用DNS来定位DC、服务器和其他计算机的，所以域的名字就是DNS域的名字。
- 12 内网渗透中，大都是通过寻找DNS服务器来确定域控制器位置（因为DNS服务器和域控制器通常配置在一台机器上）

2.3 域内权限



- 1 • 域本地组:
- 2 • 多域用户访问单域资源
- 3 • (访问同一个域), 主要用于授予本域内资源的访问权限, 可以从任何域中添加用户账号、通用组和全局组。域本地组无法嵌套在其他组中
- 4 • 全局组:
- 5 • 单域用户访问多域资源
- 6 • (必须是同一个域中的用户), 只能在创建该全局组的域中添加用户和全局组, 但可以在域森林中的任何域内指派权限, 也可以嵌套在其他组中
- 7 • 通用组: 多域用户访问多域资源, 成员信息不保存在域控制器中, 而是保存在全局编录 (GC) 中, 任何变化都会导致全林复制

2.4 域内组划分



- 1 域本地组: 来自全林作用于本域
- 2 全局组: 来自本域作用于全林
- 3 通用组: 来自全林作用于全林
- 4 本地域组的权限
- 5 Administrators (管理员组) ----最重要的权限
- 6 Remote Desktop Users (远程登录组)
- 7 Print Operators (打印机操作员组)
- 8 Account Operators (帐号操作员组)
- 9 Server Operators (服务器操作员组)
- 10 Backup Operators (备份操作员组)
- 11 全局组、通用组的权限
- 12 Domain Admins (域管理员组) ----最最最重要的权限, 一般来说域渗透是看重这个
- 13 Enterprise Admins (企业系统管理员组) ----最重要的权限, 其次是去看重这个权限
- 14 Schema Admins (架构管理员组) ----最重要的权限
- 15 Domain Users (域用户组)

2.5 A-G-DL-P策略



- 1 A 代表用户账号 (Account)。
- 2 G 代表全局组 (Global Group)。
- 3 DL 代表域本地组 (Domain Local Group)。
- 4 P 代表资源访问权限 (Permission)。
- 5 A-G-DL-P策略是一种将用户账号添加到全局组中, 然后将全局组添加到域本地组中, 并为域本地组分配资源访问权限的策略。这种策略使得来自不同域的用户能够通过全局组和域本地组的组织方式, 访问本地域中的资源。

2.6 域环境应用



- 1 • 账号集中管理
- 2 • 软件集中管理
- 3 • 环境集中管理
- 4 • 增强统一安全性

2.7 域环境架构



- 1 域控制器
 - 2 成员服务器
 - 3 客户机
 - 4 独立服务器
 - 5 见图：（单域，父域，子域，域树，域森林）
 - 6 单域是指网络环境中只有一个域，建立一个单独的域足以。
 - 7 父子域在一个域中划分出多个域，被划分的域为父域，划分出来的域为子域。
 - 8 域树中的命名空间具有连续性，并且域名层次越深，级别越低。
 - 9 域林是指一个或多个没有形成连续名字空间的域树组成的域树集合。
-

3.演示案例

```
net group /domain //获得所有域用户组列表
net group xxx /domain //显示域中xxx组的成员
net group xxx /del /domain //删除域中xxx组
net group xxx andy /del /domain //删除域内xxx 群组
中的成员
net group "domain admins" /domain //获得域管理
员列表
net localgroup administrators /domain //获得企业管
理员列表
net group "domains computers" /domain //获取域
内置administrators组用
net user /domain //获得所有域用户列表
net user xxx /domain //获得指定账户xxx的详细信息
net accounts /domain //获得域密码策略设置, 密码长
短, 错误锁定等信息
net view /domain //查询有几个域, 查询域列表
net view /domain:testdomain //查看 testdomain域中
的计算机列表
nltest /domain:trusts //获取域信任信息
net user domain-admin /domain //查看管理员登陆时
间, 密码过期时间, 是否有登陆脚本, 组分配等信息
net config Workstation //查询机器属于哪个域
net time /domain //查询主域服务器的时间
echo %logonserver% //查看登陆到这台服务器的计算
机名
net time \\192.168.50.1 //查询远程共享主机
192.168.50.1的时间
net use \\IP\ipc$ password /
user:username@domain //ipc$域内连接, 拿下文件服
务器以结合菜刀去建立ipc连接, 然后下载和阅读想要的
文件
net view \\dc1.zzhsec.com //查看域控共享情况
dir \\dc1.zzhsec.com\SYVOL /s /a &gt; sysvol.txt //
列出sysvol日志记录
xcopy \\dc1.zzhsec.com\sysvol.txt sysvol.txt /i /e /
c //远程拷贝到本地sysvol日志
net user /domain zzh 123.qwe //修改域内用户密码,
需要管理员权限
mstsc /admin //远程桌面登录到console会话解决hash
无法抓出问题
gpupdate/force //更新域策略
psexec \\192.168.50.3 -u administrator -p zzh1234 -
c gsecdump.exe -u //从域服务器密码存储文件
windows\ntds\ntds.dit导出hash值出来
tasklist /S ip /U domain\username /P /V //查看远程
计算机进程列
```

域内信息收集

windows主机信息收集

基本操作命令

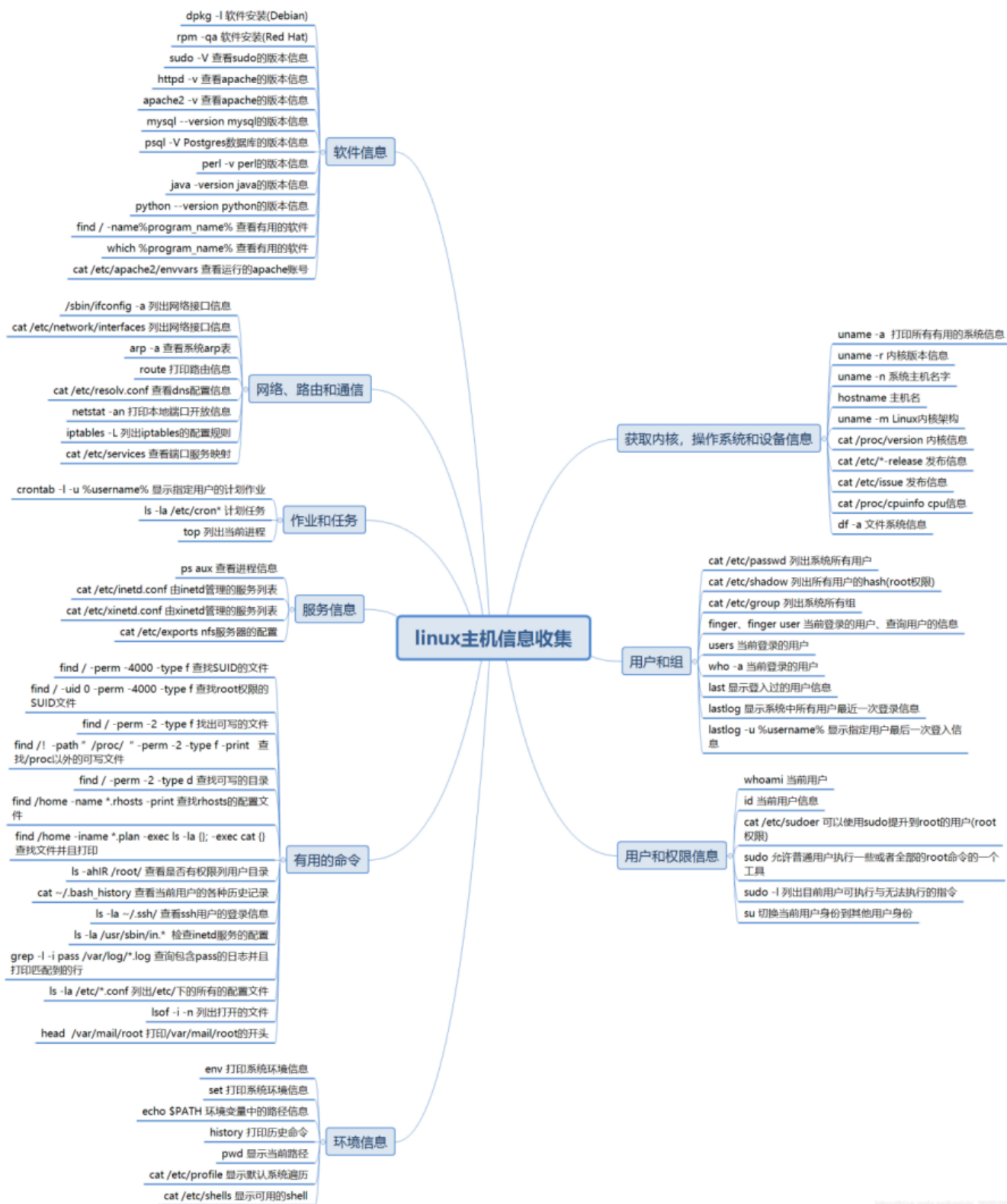
```
ipconfig/all //查看IP地址
whoami //查询账号所属权限
systeminfo //查询系统以及补丁信息
tasklist /svc //查看进程
taskkill /im 进程名称
wmic qfe get hotfixid //查看已安装过得补丁, 这个很
实用
wmic qfe list full /format:htable &gt; hotfixes.htm //
详细的补丁安装
wmic qfe //查询补丁信息以及微软提供的下载地址
ping hostname(主机名) //显示该机器名的IP
query user //查看管理员最近登陆时间
net start //查看当前运行的服务
net user //查看本地组的用户11
net localhroup administrators //查看本机管理员组有
哪些用户
net use //查看会话
net session //查看当前会话
net share //查看SMB指向的路径(即共享)
wmic share get name,path //查看SMB指向的路径
wmic nteventlog get path,filename,writable //查询
系统日志文件存储位置
net use \\IP\ipc$ password /user:username //建立
IPC会话 (工作组模式)
net use z: \\192.168.50.1 //建立映射到本机Z盘
netstat -ano //查看开放的端口
netstat -an | find "3389" //找到3389端口
net accounts //查看本地密码策略
nbtstat -A ip //netbios查询
net view //查看机器注册或许能得到当前活动状态的机
器列表, 如果禁用netbios就查看不出来
echo %PROCESSOR_ARCHITECTURE% //查看系统是
32还是64位 set //查看系统环境设置变量 net start //查
看当前运行的服务
wmic service list brief //查看进程服务
wmic process list brief //查看进程
wmic startup list brief //查看启动程序信息
wmic product list brief //查看安装程序和版本信息 (漏
源利用线索)
```

查文件命令

```
dir /b/s config.* //查看所在目录所有config.为前缀的
文件
dir /b/s *.config //查看所在目录所有config.为后缀的
文件
findstr /si password *.xml *.ini *.txt //查看后缀名文件
中含有password关键字的文件
findstr /si login *.xml *.ini *.txt //查看后缀名文件含
有login关键字的文件
```

网络命令

```
tracert IP //路由跟踪
arp -a //列出本网段内所有活跃的IP地址
route print //打印路由表
arp -s (ip + MAC) //绑定mac与ip地址
arp -d (ip + MAC) //解绑mac与ip地址
netsh firewall show config //查看防火墙策略
ipconfig/all //查看IP地址
```



http://blog.csdn.net/whale_20077029



1 域渗透的信息收集:

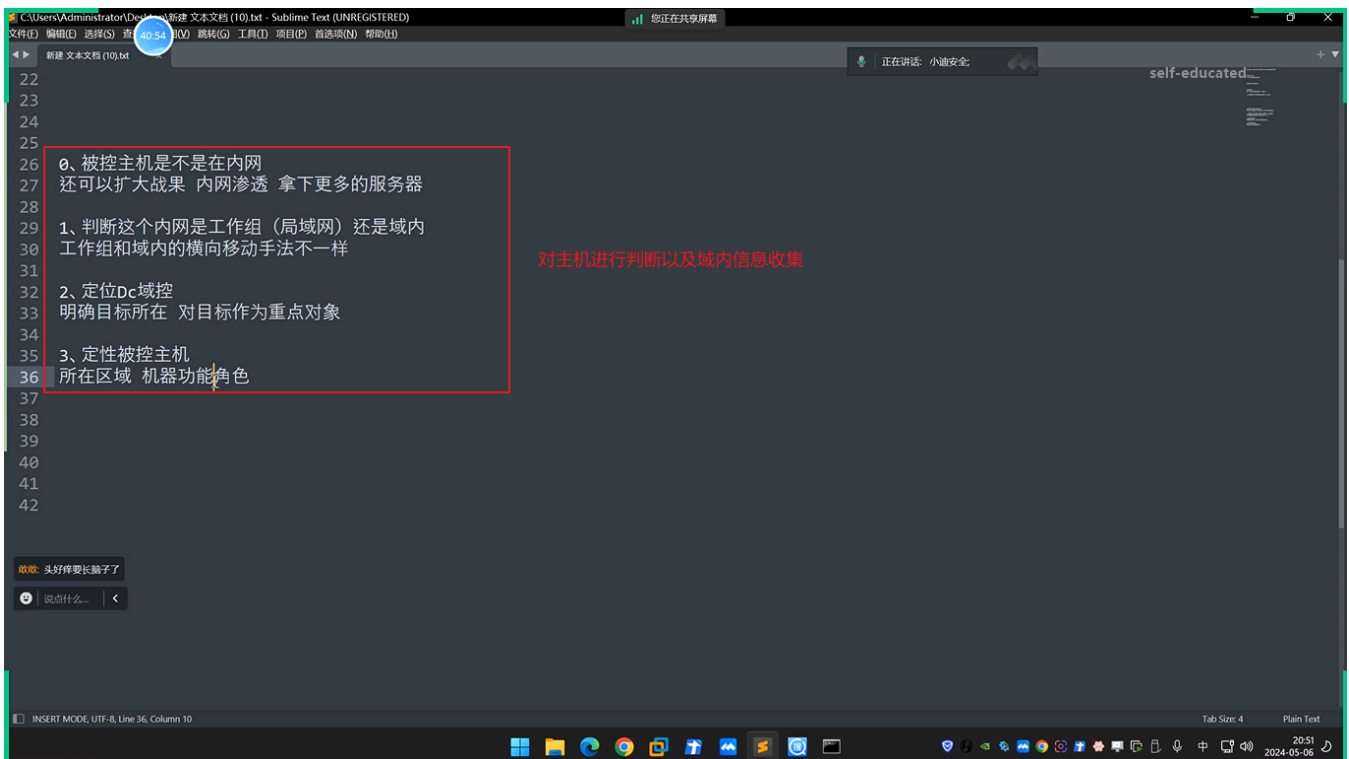
2 在攻防演练中,当完成边界突破后进入内网,信息搜集成为一个重要环节。充分获取信息可以有效提高攻击效率,因此需要明确主要的信息搜集思路,并搜集必要的信息,以提高这一阶段的质量,为后续攻击打下更好的基础。

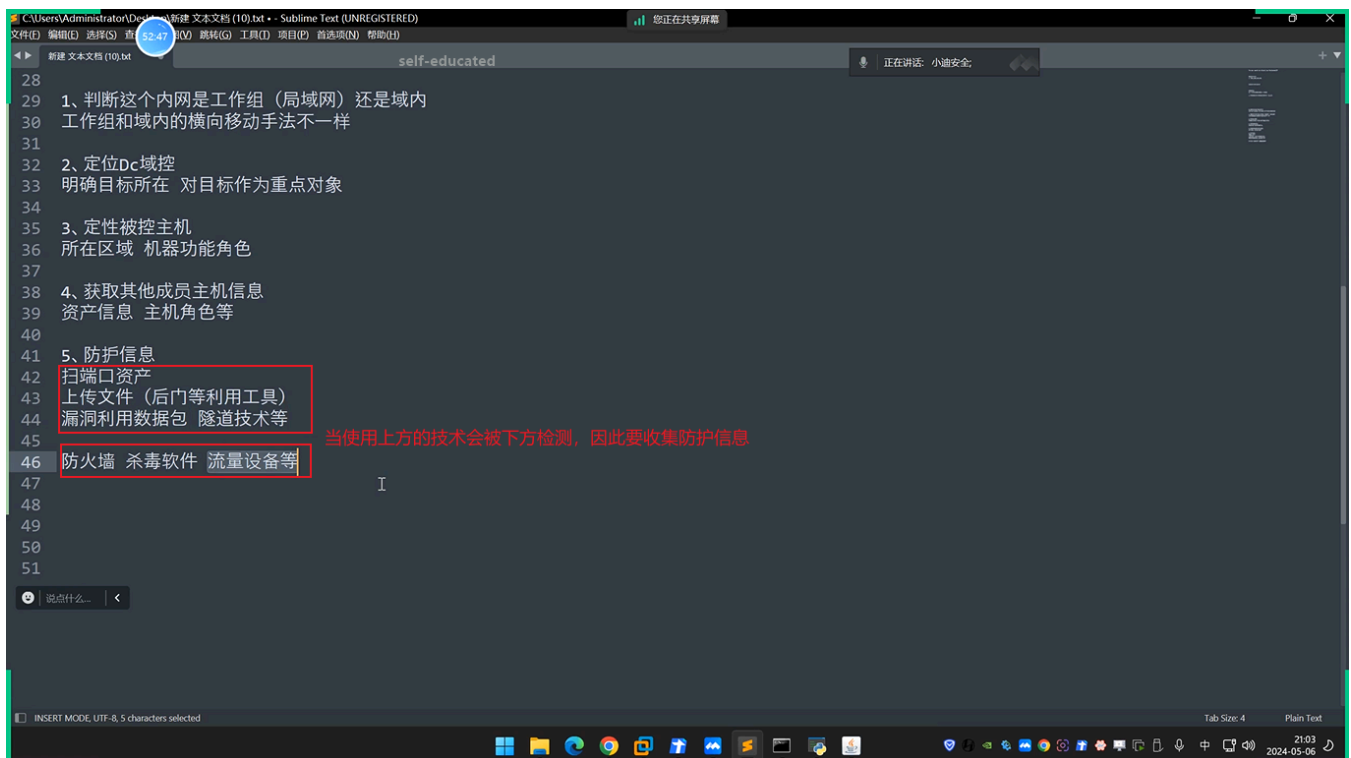
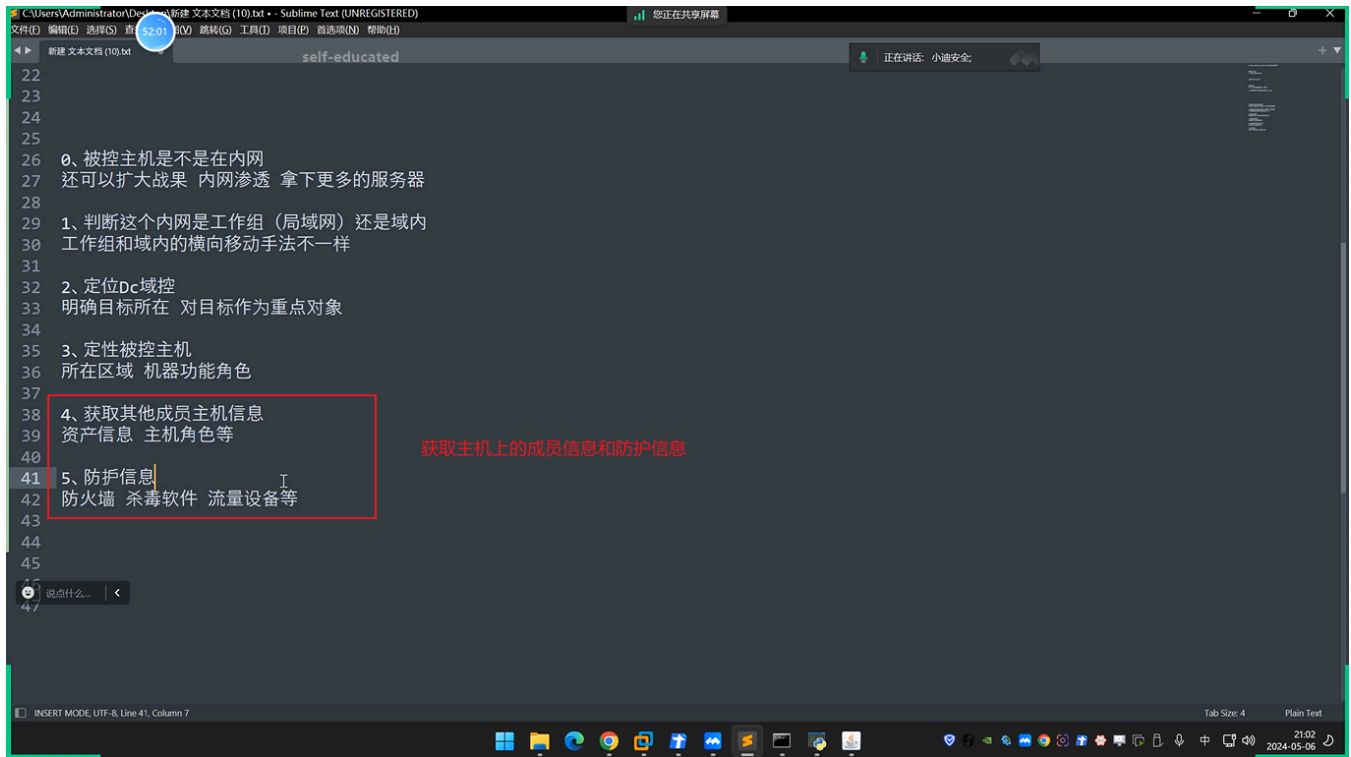
- 1 域渗透的思路就是：
- 2 通过域成员主机，定位出域控制器IP及域管理员账号，利用域成员主机作为跳板，
- 3 扩大范围，利用域管理员可以登陆域中任何成员主机特性，定位出域管理员登陆过的主机IP，设法从域成员主机内存中dump出域管理员密码，进而拿下域控制器、渗透整个内网。也可以通过域内web应用，Exchange系统，端口服务等获取权限进行横向。

3.1 信息收集-网络架构-出网&定位&服务&角色

可参考上述图片的命令。

- 1 #网络架构：
- 2 1、基本信息
- 3 IP、网关、DNS、出网判断、本机网络连接以及开放端口、本机的代理，域名是什么等





3.1.1 域内定位

- 1 2、域内定位
- 2 ipconfig /all 判断存在域-dns 有域的有dns后缀，无域的无dns后缀
- 3 net config workstation 查询当前登陆域及登录用户信息
- 4 net time /domain 获取主域名，其实这个就是主域的计算机名，再通过nslookup或ping命令来获取主域的IP地址

```
C:\Users\Administrator>net time /domain
找不到域 WORKGROUP 的域控制器。

请键入 NET HELPMSG 3913 以获得更多的帮助。

C:\Users\Administrator>ipconfig /all

Windows IP 配置

主机名 . . . . . : XIAODI
主 DNS 后缀 . . . . . :
节点类型 . . . . . : 混合
IP 路由已启用 . . . . . : 否
WINS 代理已启用 . . . . . : 否

以太网适配器 以太网:

   连接特定的 DNS 后缀 . . . . . :
   描述 . . . . . : Intel(R) Ethernet Controller (3) I225-V
   物理地址. . . . . : 58-11-22-8B-0E-EE
   DHCP 已启用 . . . . . : 是
   自动配置已启用. . . . . : 是
   IPv4 地址 . . . . . : 192.168.1.4(首选)
   子网掩码 . . . . . : 255.255.255.0
   获得租约的时间 . . . . . : 2024年5月6日 18:20:16
   租约过期的时间 . . . . . : 2024年5月7日 18:20:16
   默认网关 . . . . . : 192.168.1.1
   DHCP 服务器 . . . . . : 192.168.1.1
   DNS 服务器 . . . . . : 192.168.1.1
```

```
Windows PowerShell
版权所有 (C) 2009 Microsoft Corporation. 保留所有权利。

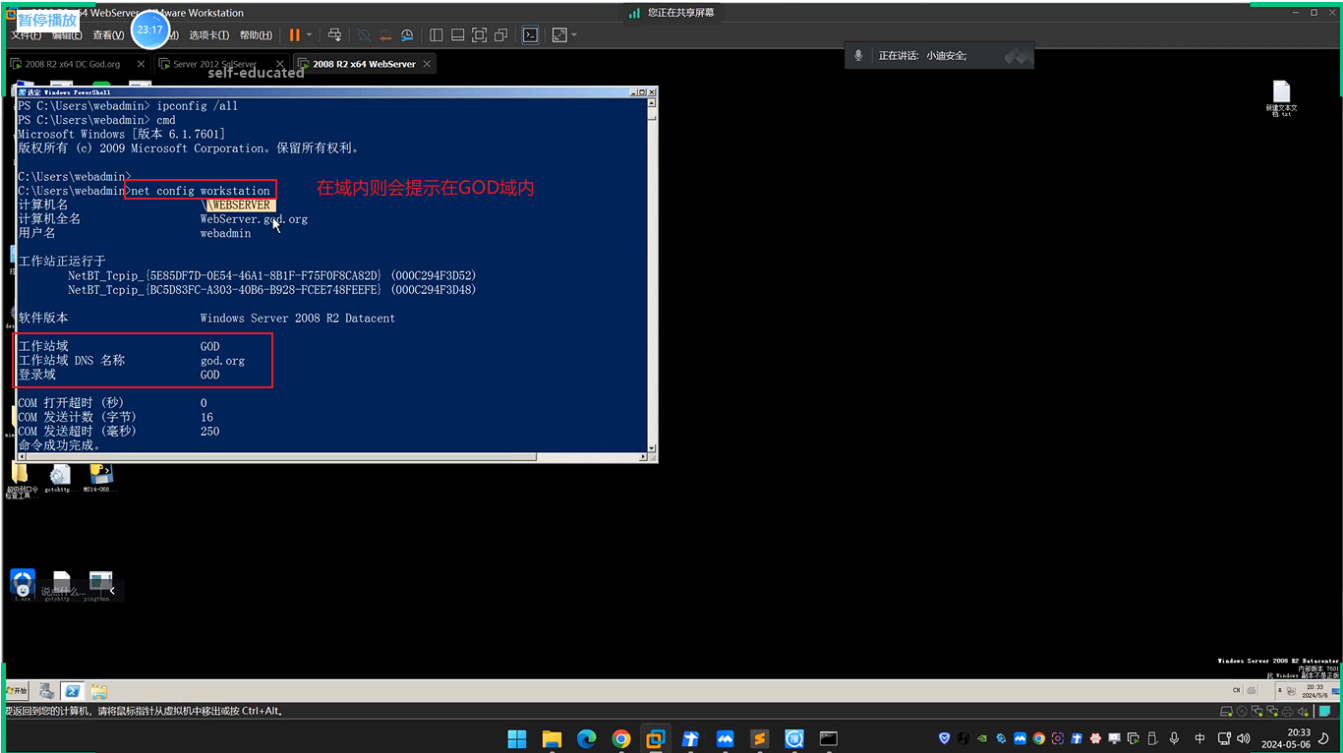
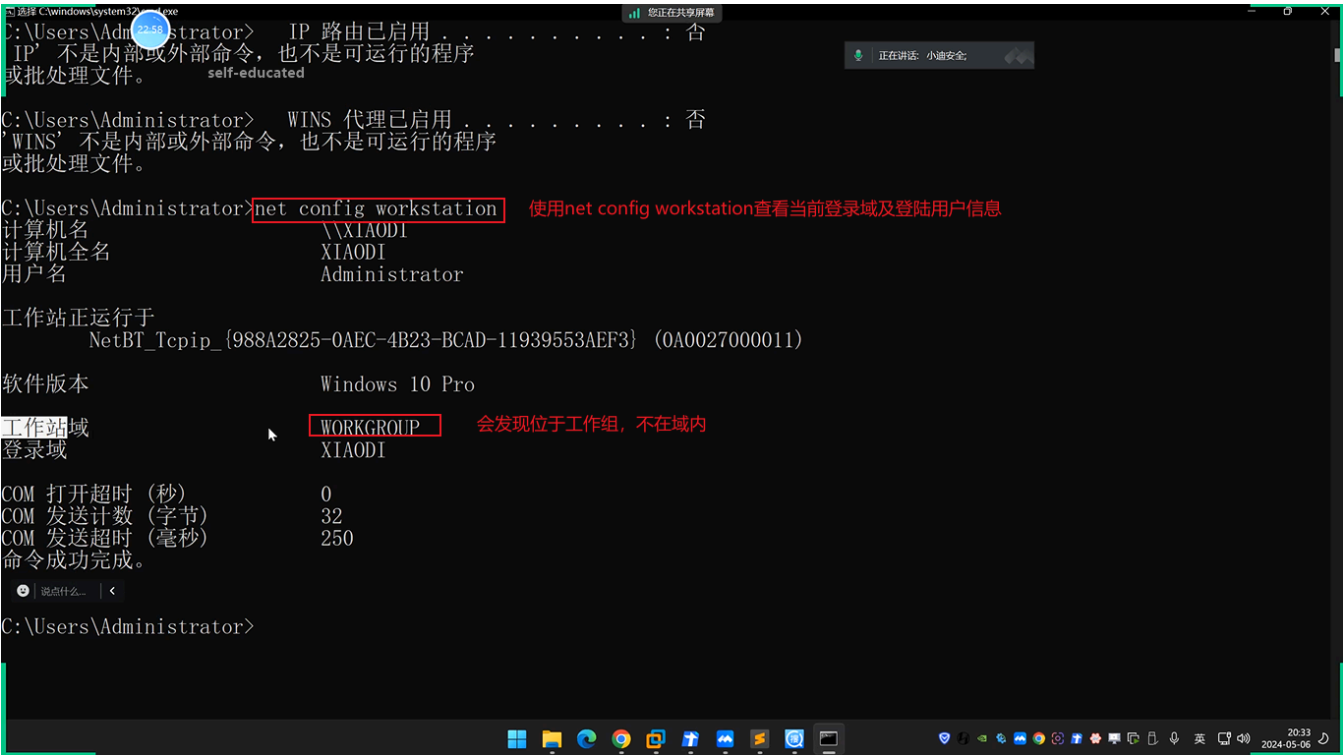
PS C:\Users\webadmin> ipconfig /all

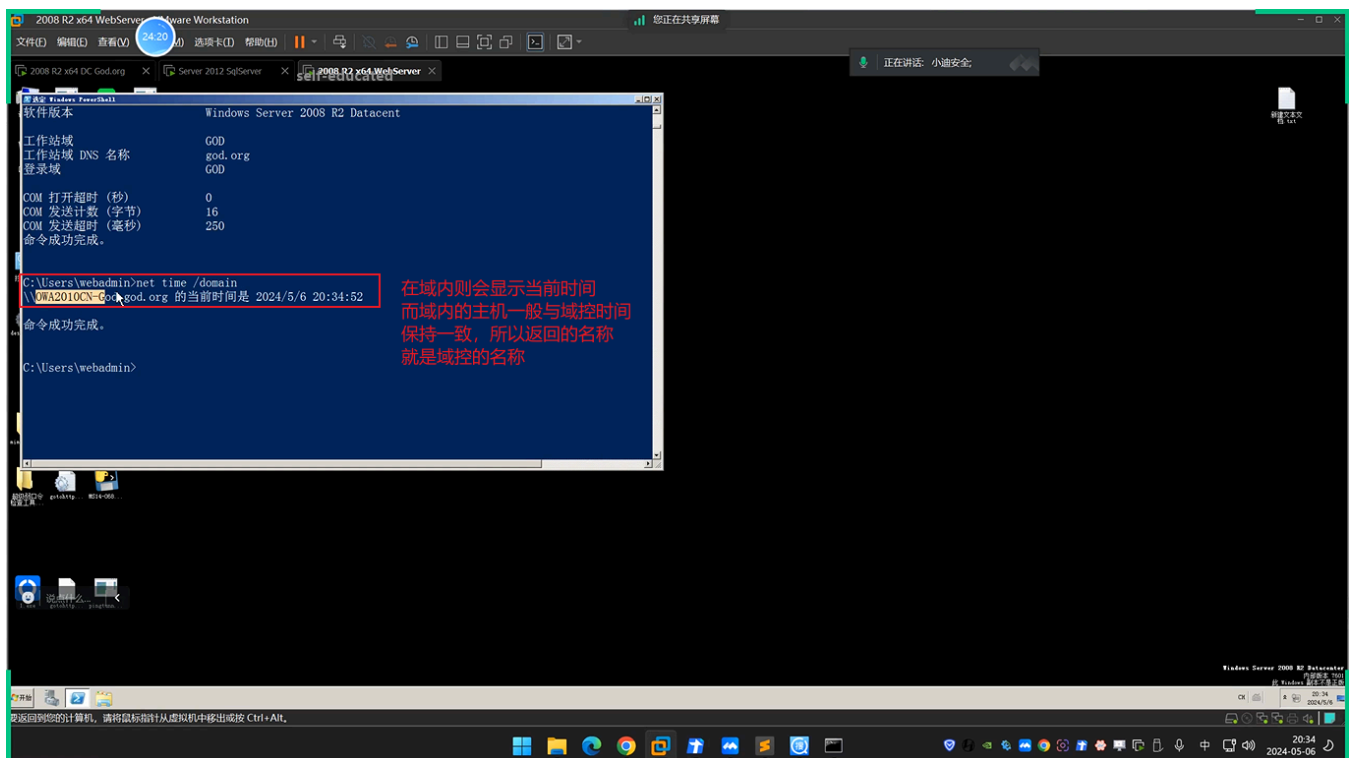
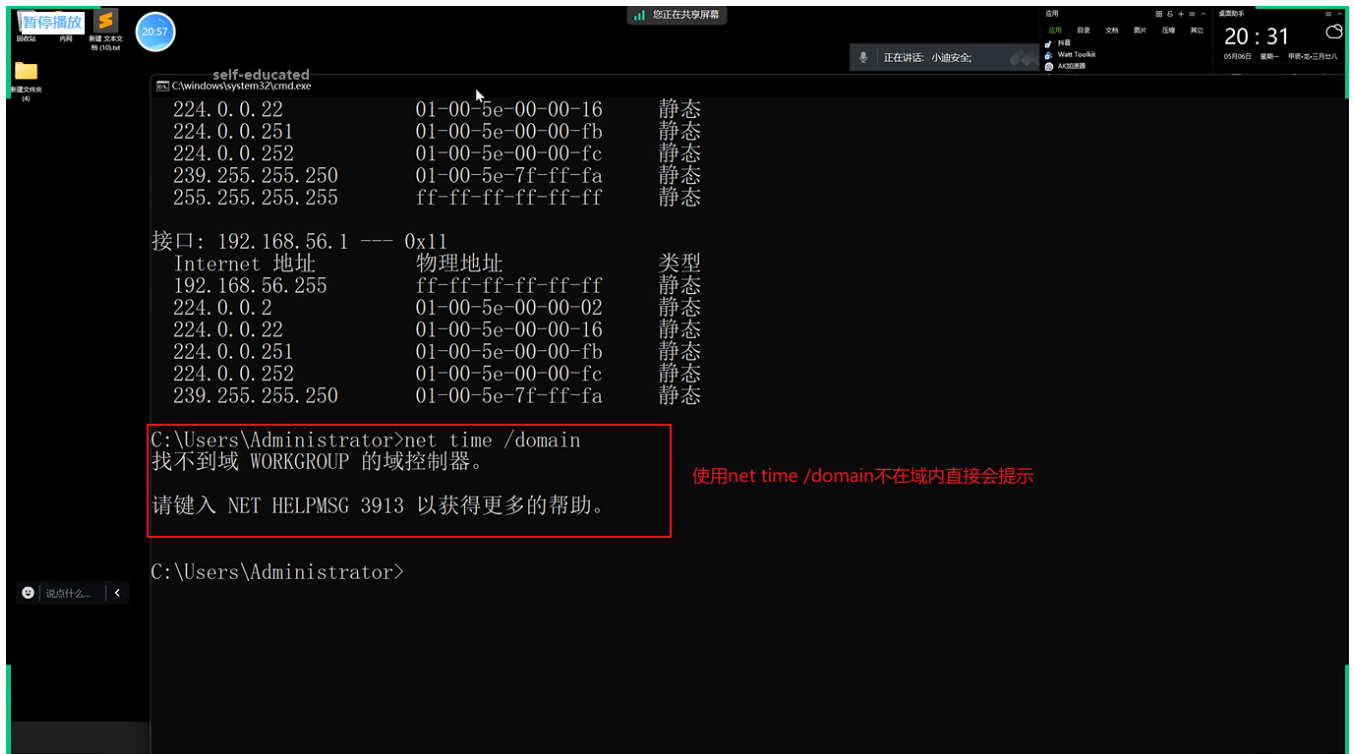
Windows IP 配置

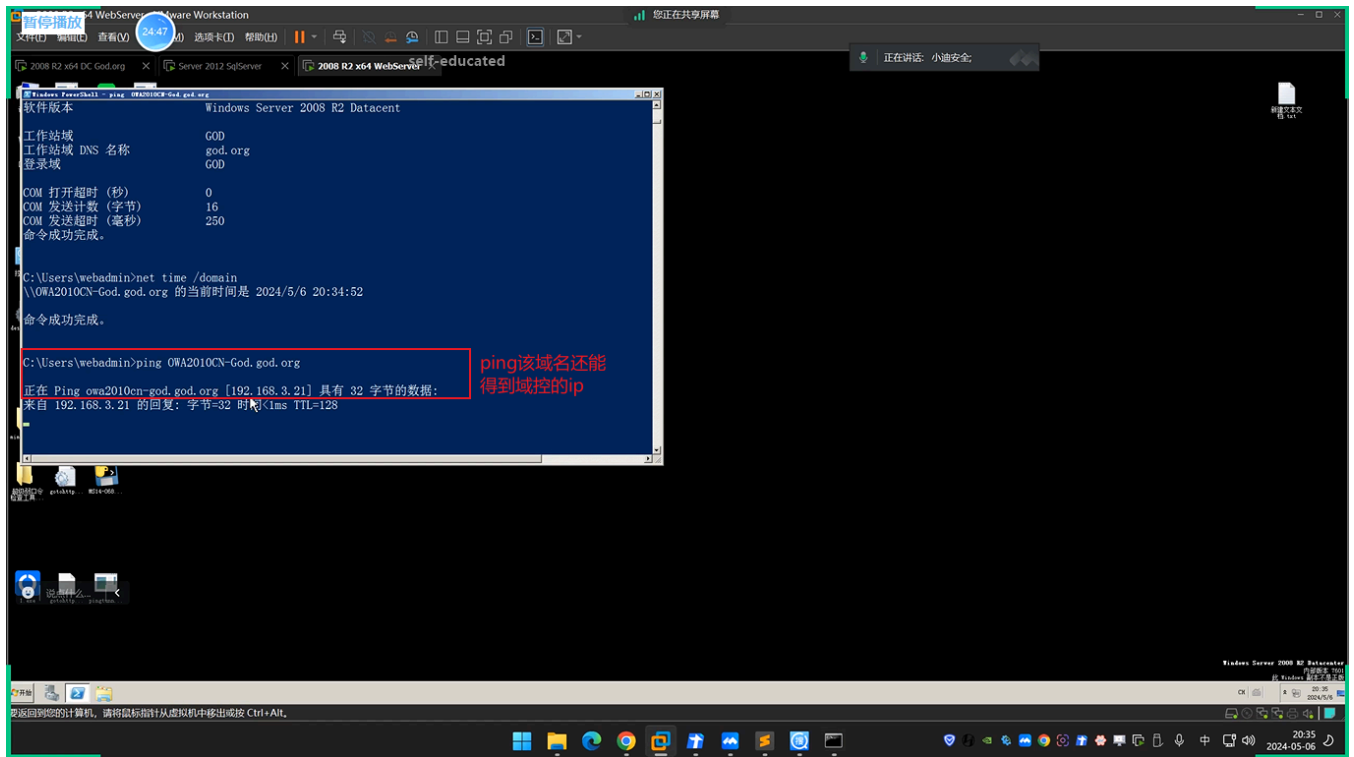
主机名 . . . . . : WebServer
主 DNS 后缀 . . . . . : god.org
节点类型 . . . . . : 混合
IP 路由已启用 . . . . . : 否
WINS 代理已启用 . . . . . : 否
DNS 后缀搜索列表 . . . . . : god.org
                                localdomain

以太网适配器 本地连接 2:

   连接特定的 DNS 后缀 . . . . . : localdomain
   描述 . . . . . : Intel(R) PRO/1000 MT Network Connection #2
   物理地址. . . . . : 00-0C-29-4F-3D-52
   DHCP 已启用 . . . . . : 是
   自动配置已启用. . . . . : 是
   本地链接 IPv6 地址. . . . . : fe80::c9f1:706d:28fa:e80d%14(首选)
   IPv4 地址 . . . . . : 192.168.139.144(首选)
   子网掩码 . . . . . : 255.255.255.0
```



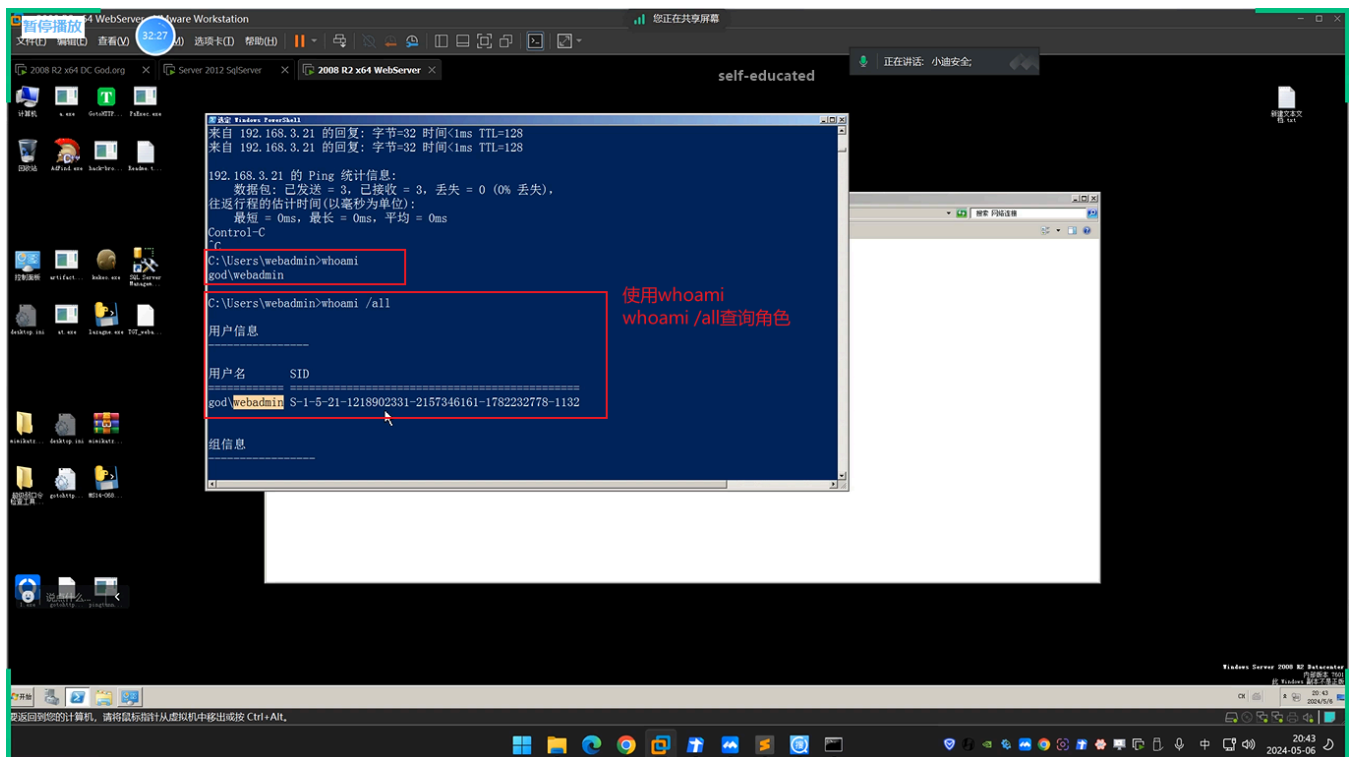


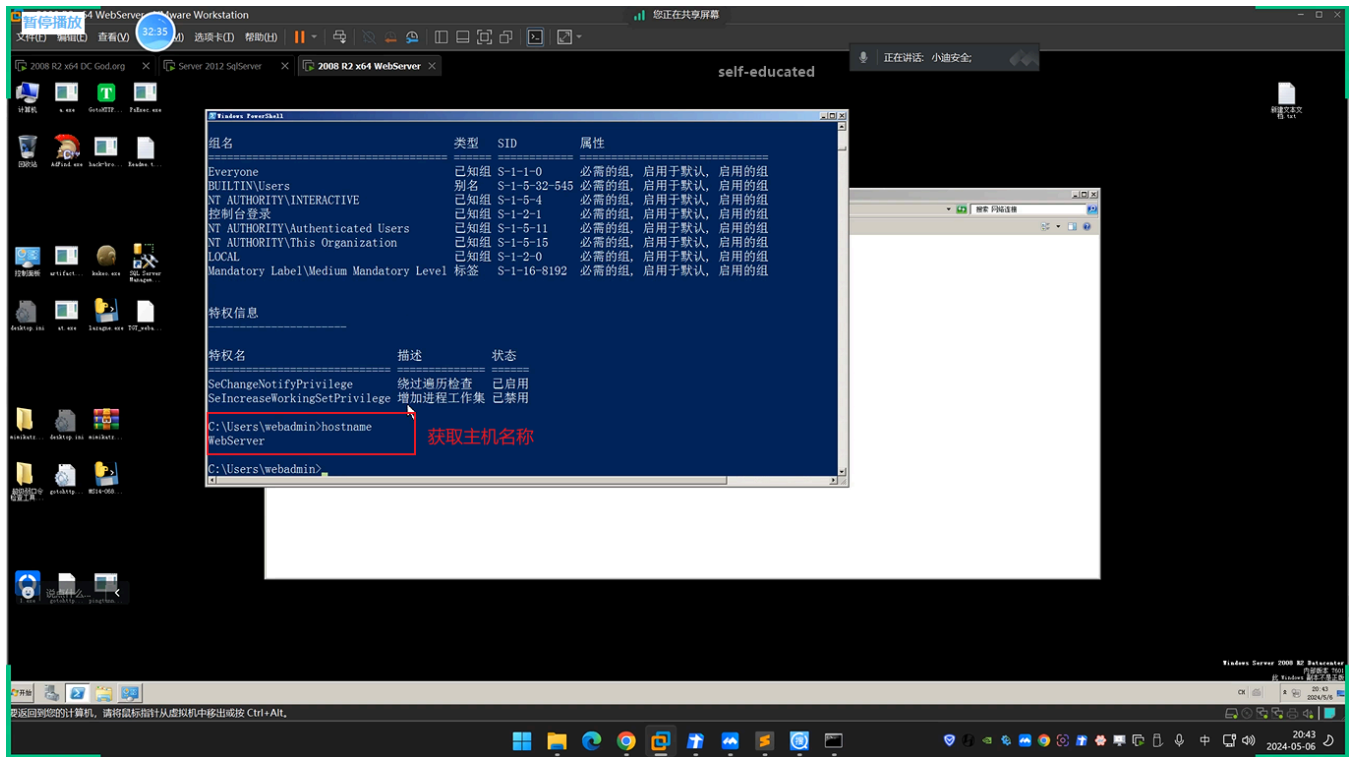


3.1.2 域内角色



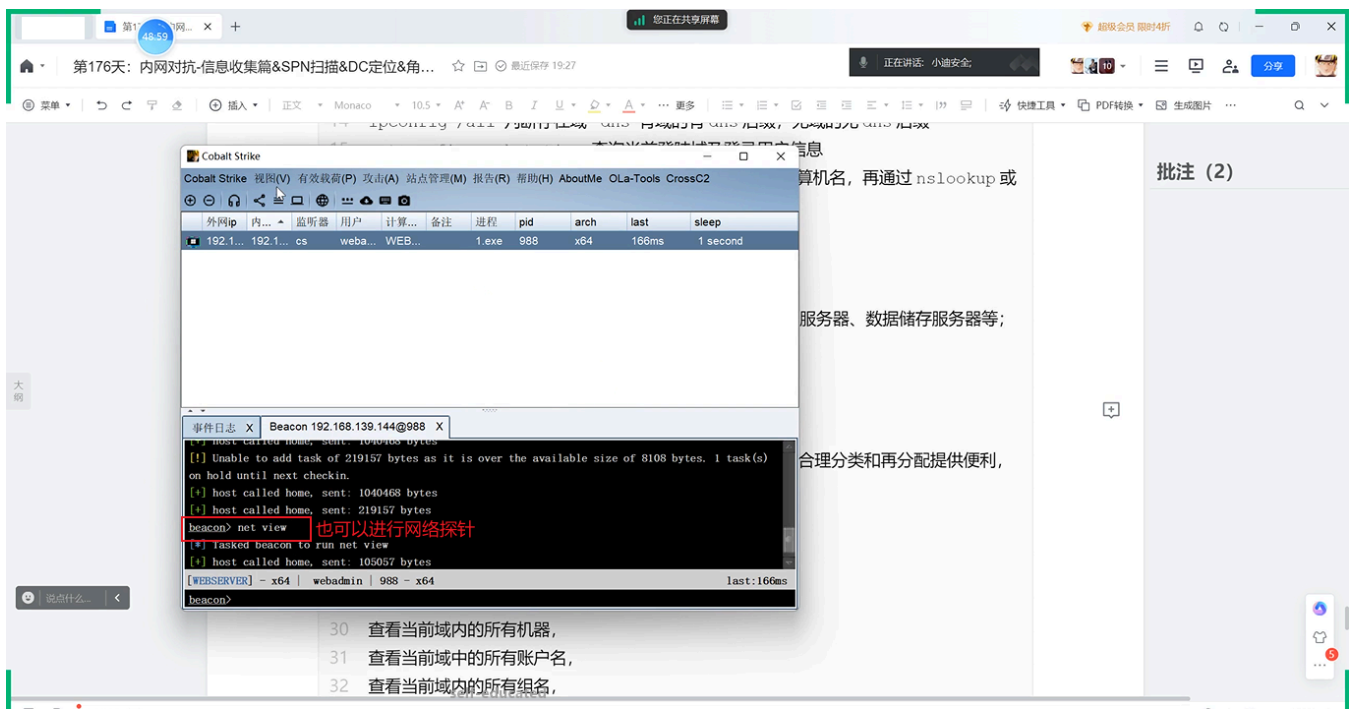
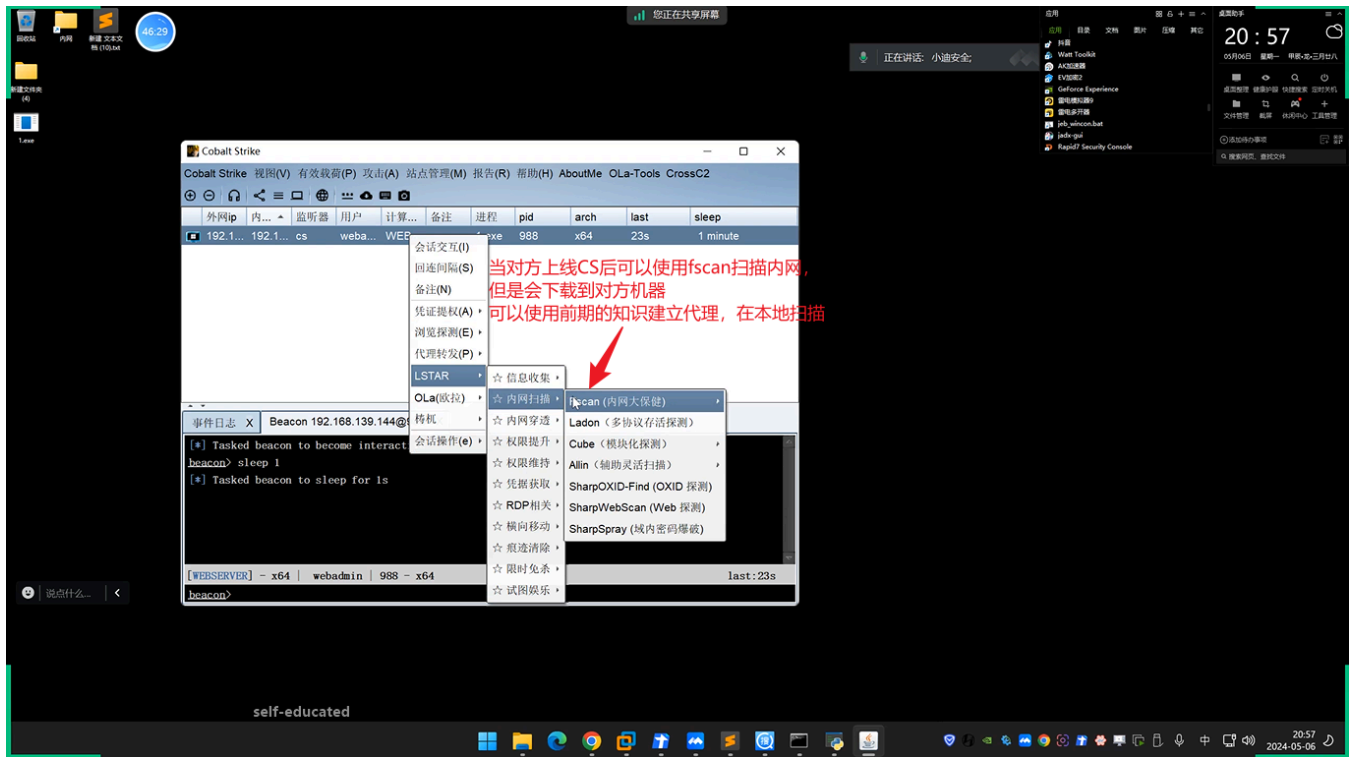
- 1 3、域内角色
- 2 根据用户名，计算机名，IP地址等多方位去分析定性
- 3 DMZ区、办公区、生产区、核心DB、核心业务区等等；
- 4 WEB服务器、开发服务器、文件服务器、代理服务器、DNS服务器、数据储存服务器等；

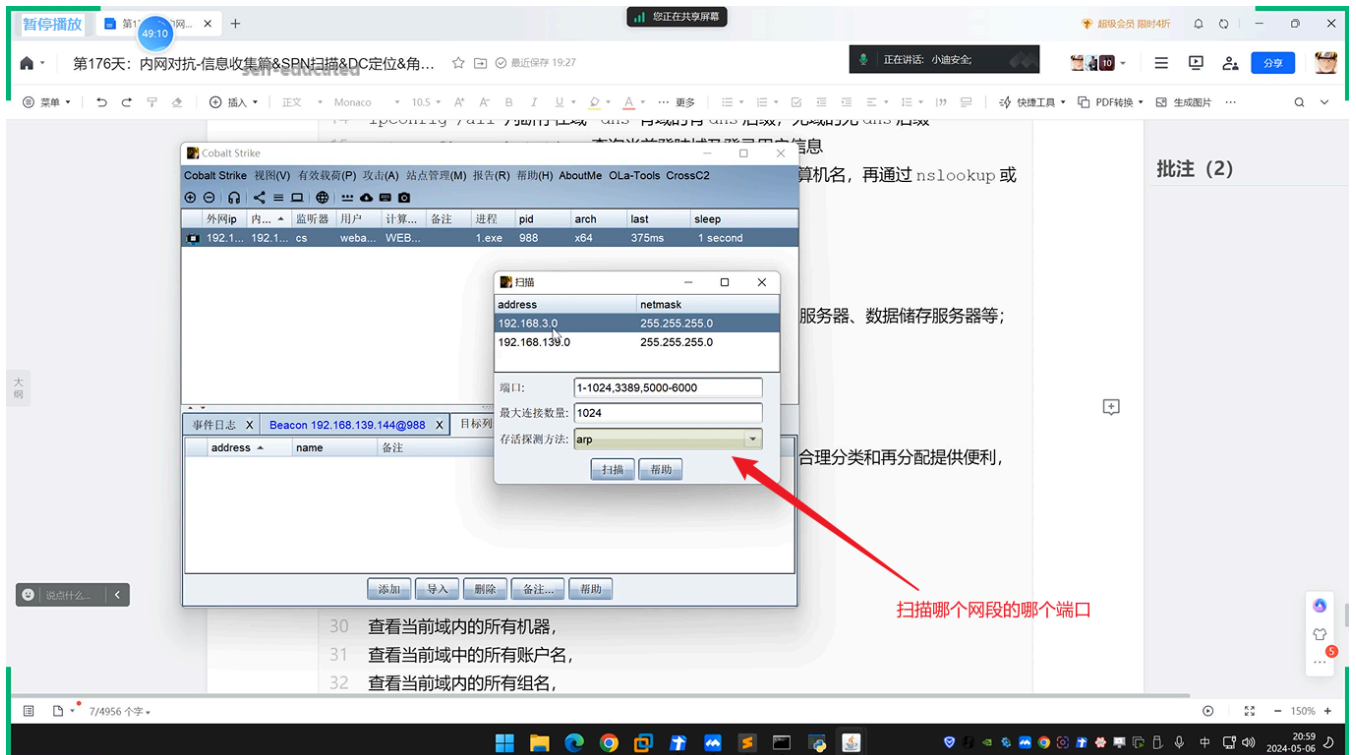
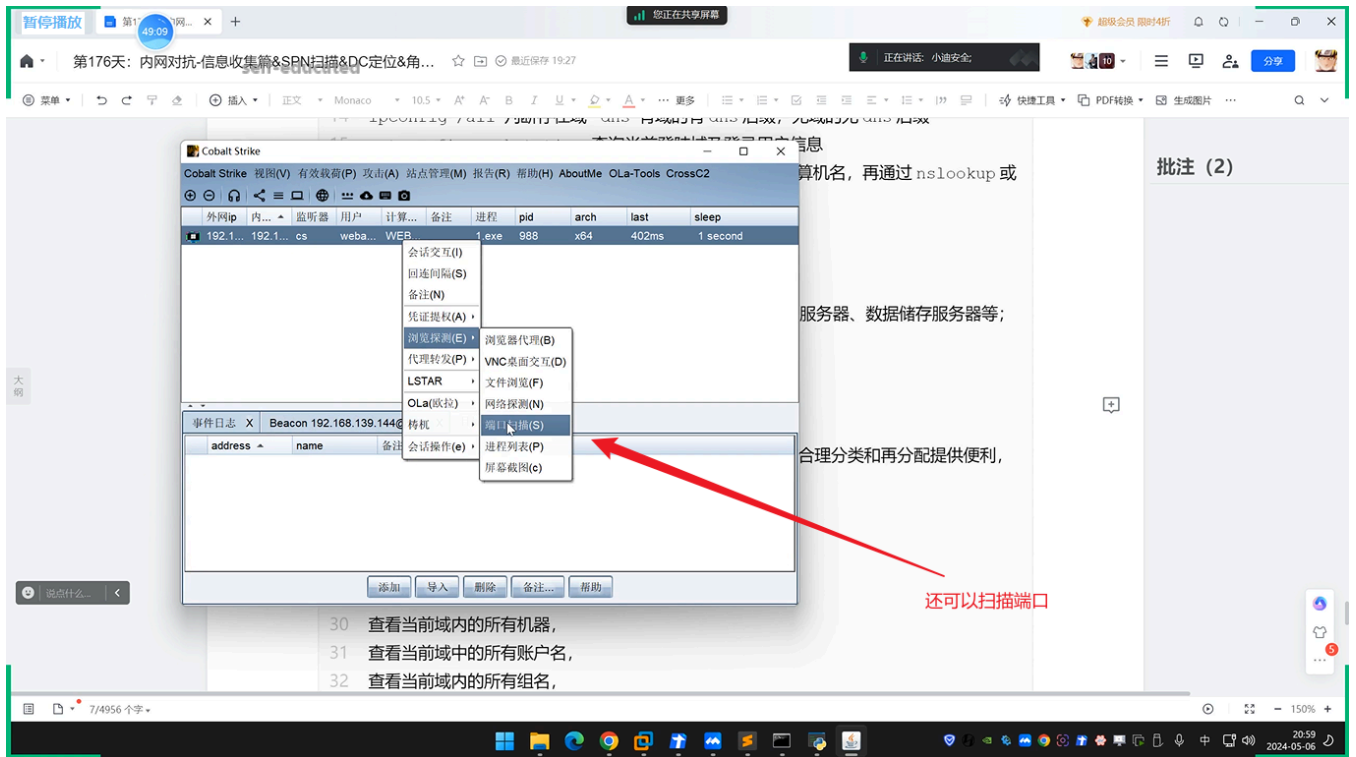


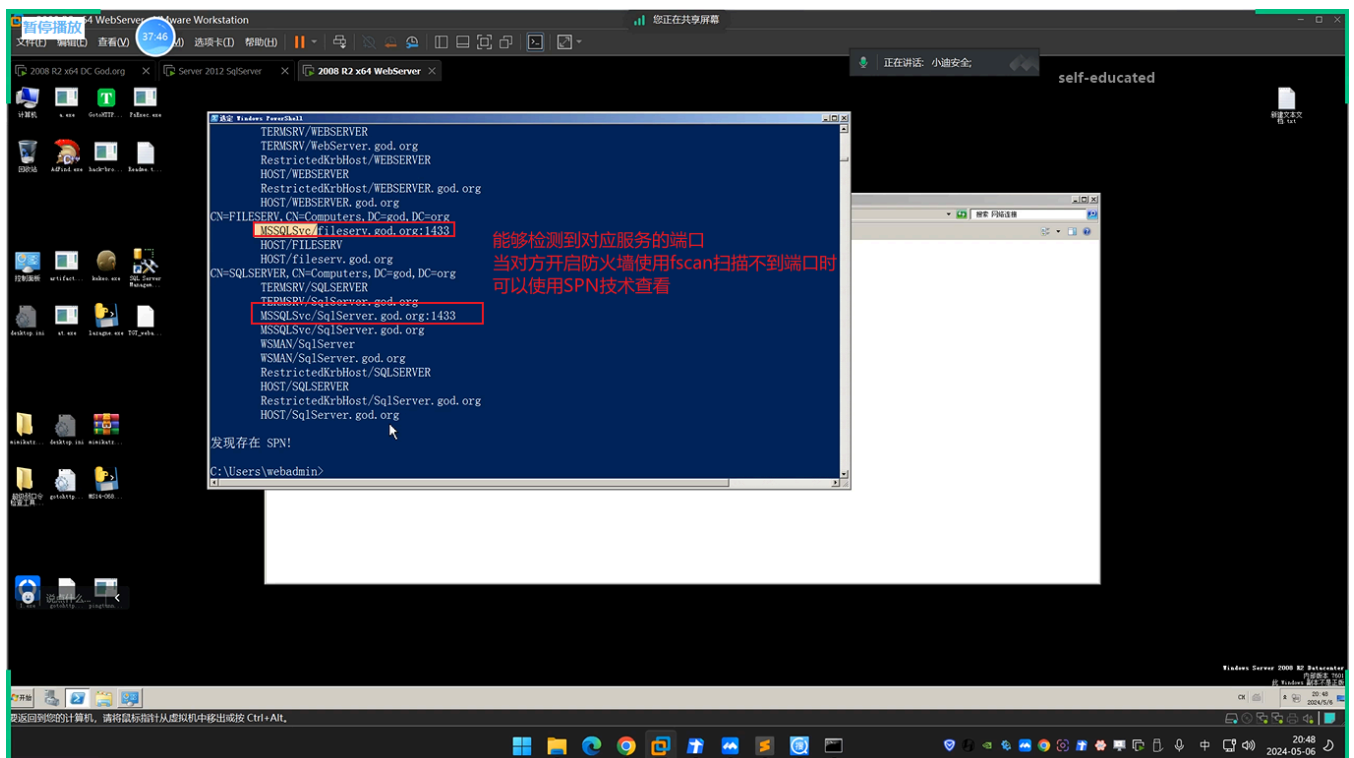
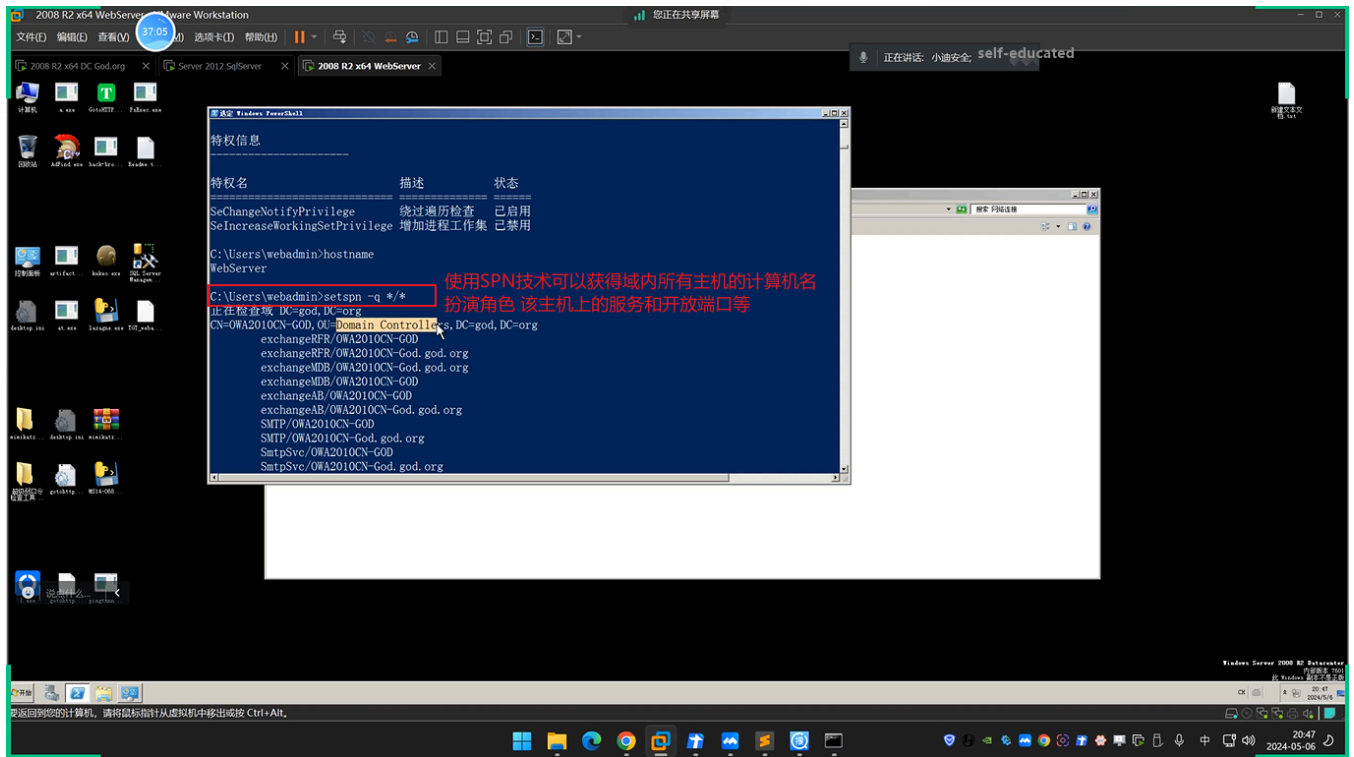


3.1.3 其他信息

- 4、其他信息
- 端口扫描（arp netbios等扫描）
- Fscan C2自带功能等
- setspn技术(Service Principal Name)
- 在域环境中运行的应用包含了多种资源，为了对资源的合理分类和再分配提供便利，微软给域内的每种资源分配了不同的服务主题名称即 SPN
- setspn -q */*
- setspn -T god.org -q */*







3.2 信息收集-安全防护-杀毒&防火墙&DMZ等



- 1 DMZ是为了解决安装防火墙后外部网络不能访问内部网络服务器的问题，而设立的一个位于内部网络与外部网络之间的缓冲区，在这个网络区域内可以放置一些公开的服务器资源。例如FTP服务器、E-Mail服务器及网站服务器等允许外部用户访问这些服务器，但不可能接触到存放在内网中的信息，就算黑客入侵DMZ 中服务器，也不会影响到公司内部网络安全，不允许任何外部网络的直接访问，实现内外网分离，在企业的信息安全防护加了一道屏障。

```
1 1、防火墙
2 2、杀毒软件
3 3、流量监控等
4 netsh firewall show config
5 netsh advfirewall set allprofiles state off
6 https://github.com/wwl012345/AVCheck
```

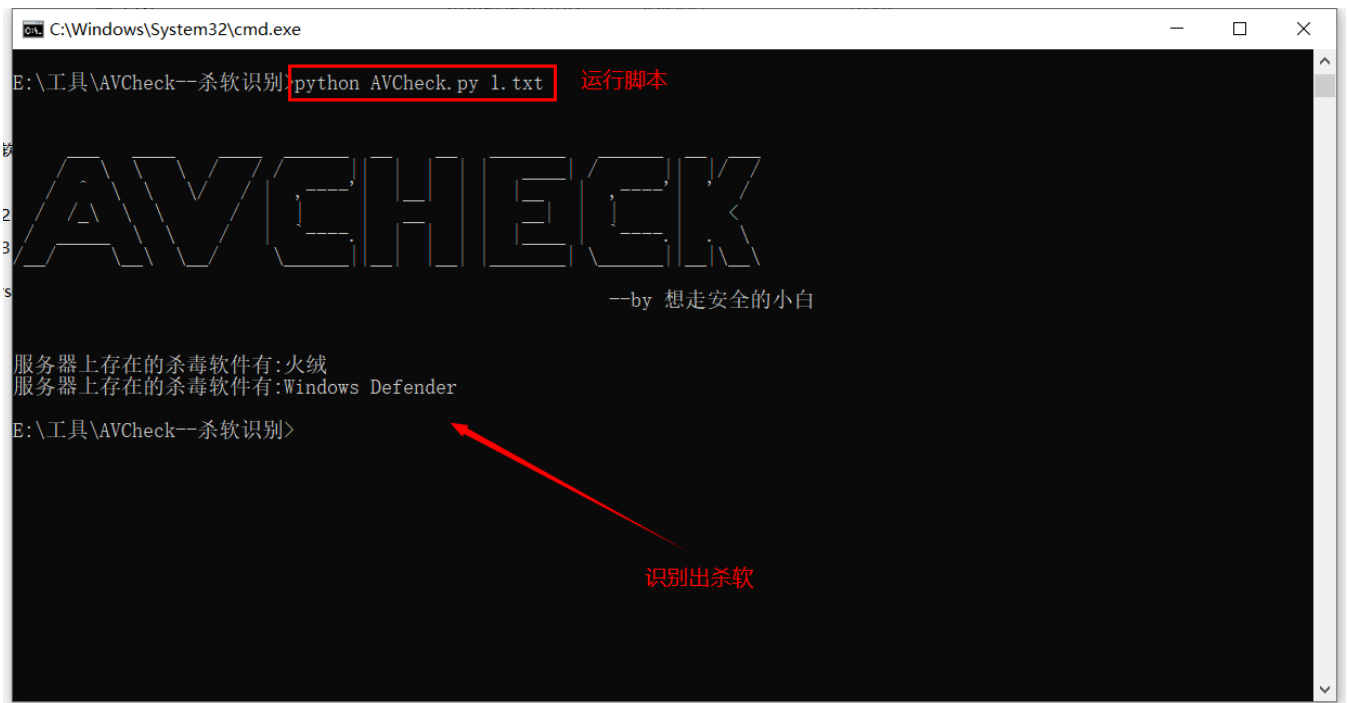
```
1 tasklist /svc >> 1.txt
2 python AVCheck.py 1.txt
```



```
C:\Windows\System32\cmd.exe
Microsoft Windows [版本 10.0.18362.175]
(c) 2019 Microsoft Corporation。保留所有权利。

E:\工具\AVCheck--杀软识别>tasklist /svc >> 1.txt
```

导出进程



```
C:\Windows\System32\cmd.exe

E:\工具\AVCheck--杀软识别>python AVCheck.py 1.txt
```

运行脚本

```
AVCHECK
—by 想走安全的小白

服务器上存在的杀毒软件有:火绒
服务器上存在的杀毒软件有:Windows Defender

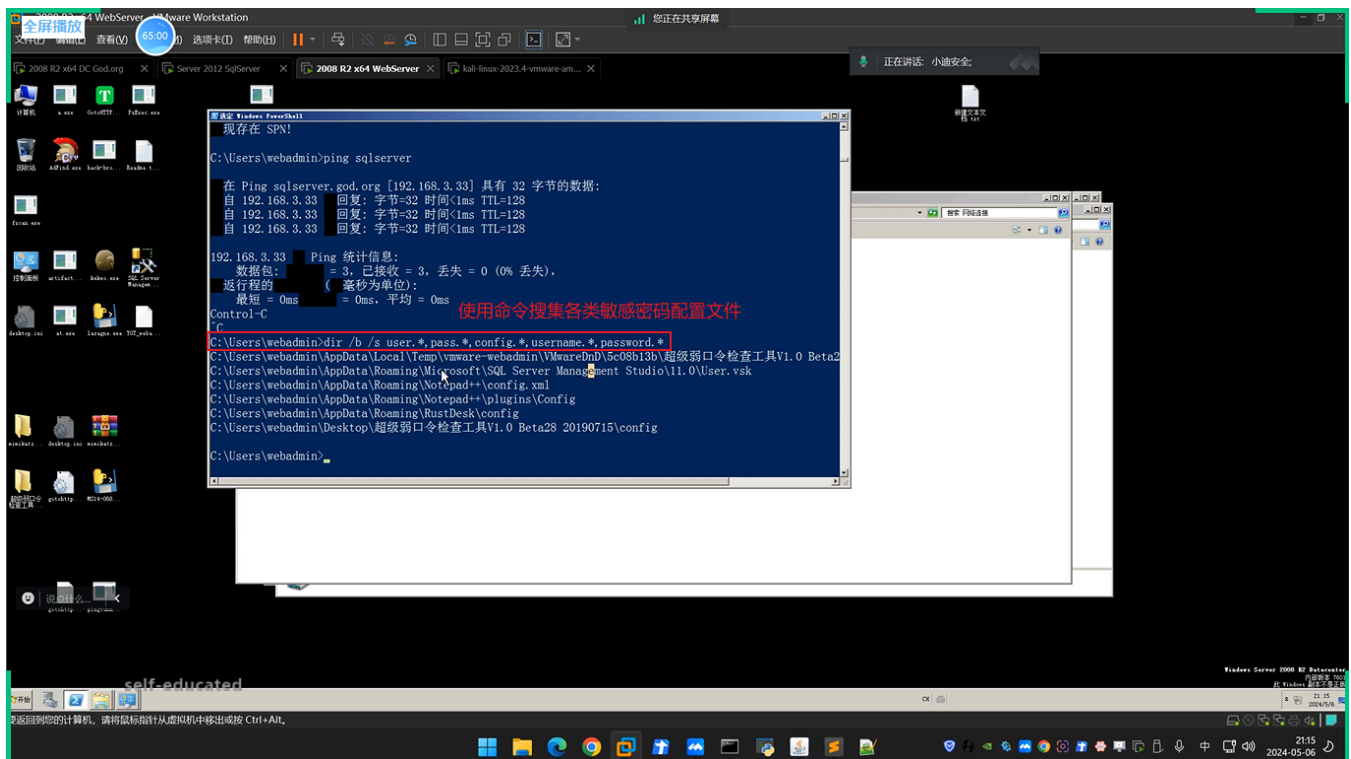
E:\工具\AVCheck--杀软识别>
```

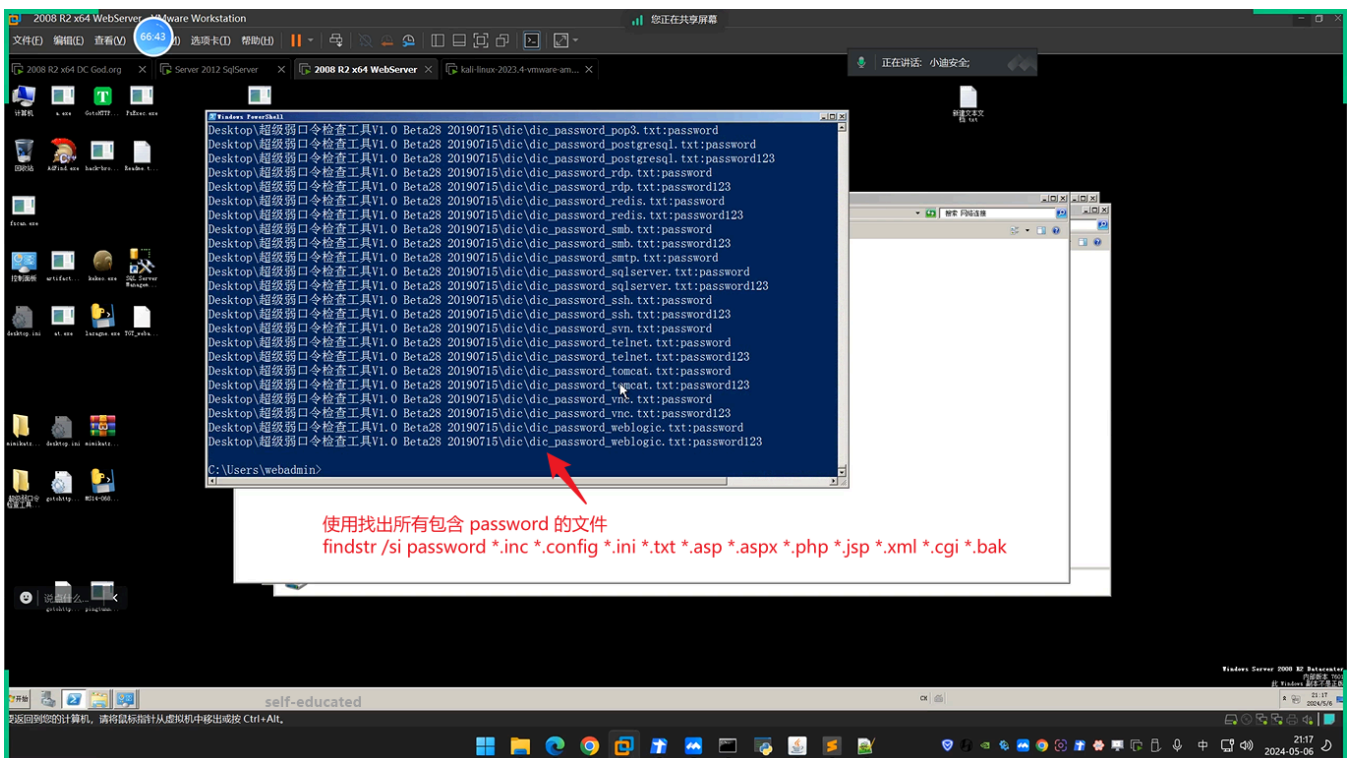
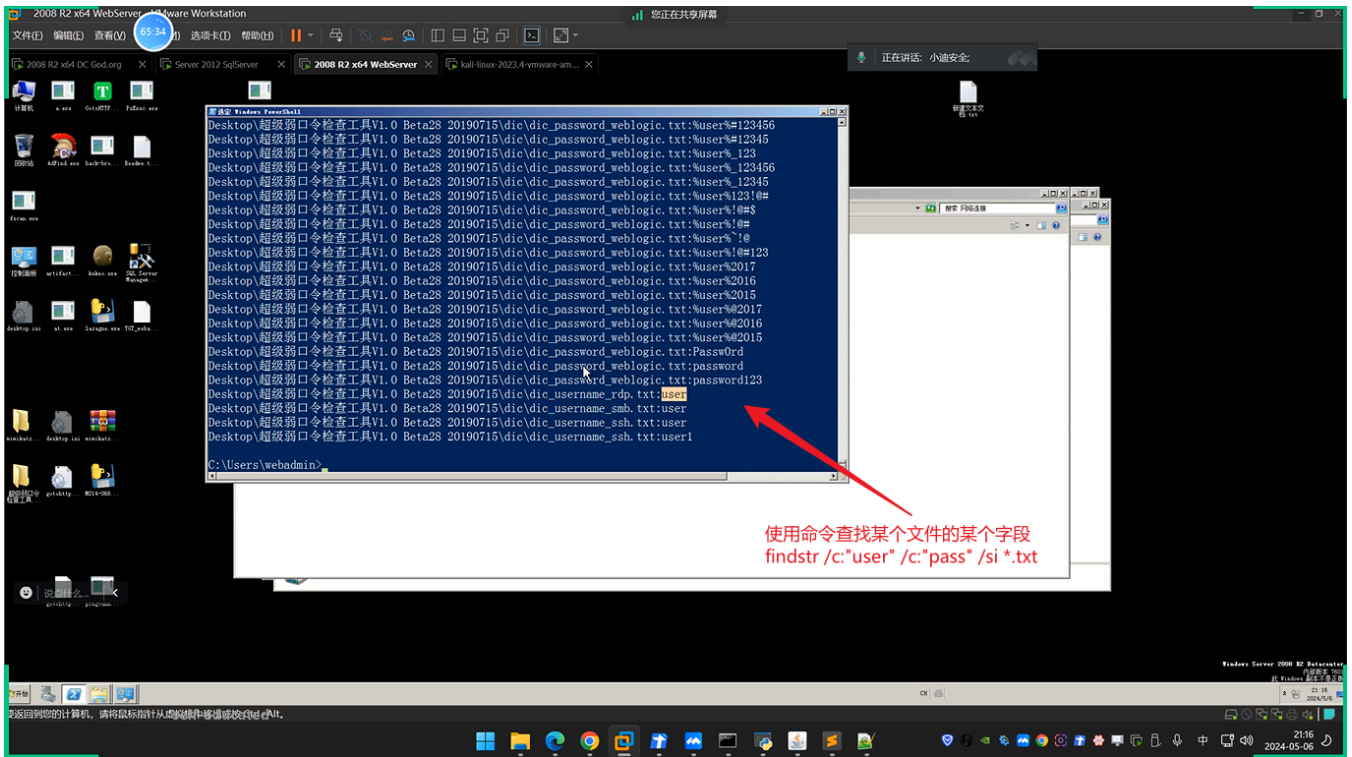
识别出杀软

3.3 信息收集-密码凭据-系统&工具&网站&网络

```
1 #凭据口令:
2 1、系统凭据 Mimikatz
3 2、浏览器存储 HackBrowserData
4 3、三方工具存储 SharpDecryptPwd
5 4、web应用相关配置 见具体web程序
6 https://github.com/gentilkiwi/mimikatz
7 https://github.com/uknowsec/SharpDecryptPwd
8 https://github.com/moonD4rk/HackBrowserData
9 https://mp.weixin.qq.com/s/SDu4rw35-Atu5fiaNhwqrA
10 5、补充其他搜索:
11 使用命令搜集各类敏感密码配置文件
```

```
12 dir /b /s user.*,pass.*,config.*,username.*,password.*
13 使用命令查找某个文件的某个字段
14 findstr /c:"user" /c:"pass" /si *.txt
15 使用找出所有包含 password 的文件
16 findstr /si password *.inc *.config *.ini *.txt *.asp *.aspx *.php *.jsp *.xml *.cgi
   *.bak
17 具体:
18 1. 站点源码备份文件、数据库备份文件等
19 2. 连接工具存储密码, xshell, Navicat等
20 3. 浏览器保存密码、浏览器Cookies
21 4. 其他用户会话、3389和ipc$连接记录、回收站内容
22 5. Windows 保存的WIFI密码
23 6. 网络内部的各种帐号和密码, 如: Email、VPN、FTP、OA等
```





剩余工具下节课进行演示。